AI Governance Practitioner Toolkit and Content Engine

Prepared: 16 April 2026 **Audience:** Solo-operator consulting practice serving SMB and mid-market owner-operators **Scope:** Prompt B of a two-part series. Builds on the foundation research in Prompt A (definitions, regulatory landscape, implementation patterns, document anatomy, competitive positioning). **Purpose:** Equip the practitioner to go to market immediately: discovery sessions, objection handling, implementation roadmap, content engine, an agent spec, and a mastery roadmap.

PART 1: THE DISCOVERY SESSION FRAMEWORK

The discovery session is the product before the product. If it is generic, the engagement will be generic. If it surfaces a specific, named risk in the first 45 minutes, the follow-on engagement sells itself. This section gives you the full session: structure, diagnostic questions, maturity model, and the post-session artifact that circulates inside the client's org and pulls them toward a contract.

1.1 Session Structure and Time Allocation

Total time: 60 minutes. Virtual or in person. No slides. One shared document opened in front of the client, populated live.

The session has five phases. Time allocations are floors, not ceilings. Move faster if the client is ready; never skip a phase.

Phase 1: Frame (5 minutes)

Open with a version of this, in your own voice:

> "I run these sessions the same way every time. I am going to ask you a specific set of questions. Some will be familiar. Some will surprise you. At the end you get a one-page read on where you actually are, the three risks that matter most for your situation, and a recommendation on what to do next. You do not need to have anything prepared. You do not need to sell me on where you are. The more honest you are in the next 45 minutes, the more useful the read is."

Then one scoping question: "Before we start, what triggered this conversation? What changed in the last 30 days that made this worth an hour of your time?"

Write the trigger verbatim at the top of the shared doc. It anchors everything downstream. Trigger types you will hear most often: insurance renewal questionnaire, enterprise prospect sent an AI addendum, board asked, employee incident, competitor shipped something, founder read an article.

Phase 2: Current State Scan (20 minutes)

Run the five diagnostic categories in Section 1.2 below. Do not lecture. Do not explain frameworks. Do not define terms unless asked. Your job is to fill in the shared doc with their answers in their own words.

Tell them: "I am taking notes in a shared doc. You will see everything I write. If I misphrase something, stop me."

Phase 3: Live Maturity Read (10 minutes)

With the current-state notes in front of both of you, say: "Based on what you just told me, here is where I read you as being." Walk through the four-level maturity model (Section 1.3). Name the level, name the immediate risk, name the single next step.

Do not hedge. Do not say "it depends." If they are at Level 0, say "You are at Level 0. The immediate risk is X. The single next step is Y."

This is the moment the session earns its fee. Most consultants soften here. Don't.

Phase 4: Priority Stack (15 minutes)

Name the three risks that matter most for this specific org. Not generic risks. The three that your 20 minutes of scanning surfaced.

For each risk: one sentence on what it is, one sentence on what happens if they do nothing for 90 days, one sentence on what the simplest containment move is.

Then ask them: "Which of these three worries you most?" Their answer determines the follow-on engagement.

Phase 5: Close (10 minutes)

The closing move is a specific menu, not an open question.

> "Based on what we just covered, I see two or three ways I could be useful. The first is the simplest and most common: an AI use inventory, two weeks, fixed fee, you end up with a list of every AI tool touching your business with a risk read on each. That is usually where people start. The second, if the vendor or insurance pressure is real, is a one-page jurisdictional applicability map plus a six-page acceptable use policy, four weeks, so you have something to hand the counterparty. Third, if the board pressure is the real driver, a governance framework and policy bundle, six to eight weeks. Which of those three fits the pressure you are actually under?"

Three things to notice about that close:

- It presents three fixed-scope options, not a blank estimate.
- It uses their own trigger language (vendor pressure, insurance, board). You wrote the trigger down in Phase 1 for this moment.
- It ends with a question that forces a choice between your three, not between you and nothing.

If they pick one, say "I will send you a one-page scope document tomorrow morning with the exact deliverable, timeline, and fee. If it matches what you need, we start next week."

If they hesitate, say "Send me the trigger document (the insurance questionnaire, the vendor addendum, the board email). I will look at it and send you a recommendation by end of day. No charge."

Never leave a discovery session without either a scope commitment or a named artifact to look at. One of those two moves must happen.

1.2 Diagnostic Questions

Run these in order. Write answers verbatim in the shared doc. Do not paraphrase. Most consultants listen for the answer they expected; the practitioner writes down the answer they actually got.

Category A: Current AI Usage (6 questions, ~4 minutes)

A1. What AI tools does your company officially use, by name, as of today? (ChatGPT Team, Copilot, Gemini for Workspace, Claude for Work, Jasper, anything else.)

A2. What AI features are built into the SaaS tools you already pay for, that you know you have but are not sure if anyone is using? (Gong AI summaries, HubSpot AI, Notion AI, Zoom AI Companion, Slack AI, HR platform resume screeners.)

A3. What AI tools do you know employees are using that are not officially sanctioned? If the answer is "none," ask the follow-up: "When did you last check?"

A4. Has anyone built anything in-house that uses AI? A custom GPT, an automation, a script that calls an API? (Founders will say no; dig one level: "Has your dev team mentioned anything like that in the last two quarters?")

A5. Is any AI system making or influencing decisions about customers, employees, candidates, credit, pricing, or content moderation? Name each one.

A6. How do people in your company currently decide whether it is okay to paste something into ChatGPT?

Red flag if: A1 has more than 3 tools and A6 is "I don't know" or "they just do." That combination is the shadow AI disclosure problem in real time.

Category B: Risk Exposure (5 questions, ~4 minutes)

B1. Where do your customers live? Any in the EU? Any in California, Colorado, Texas, Illinois, New York?

B2. Where do your employees live? Same question.

B3. Do you operate in healthcare, banking, insurance, consumer lending, hiring tech, housing, education with federal aid, or any federal contracting?

B4. Has any AI system produced an output in the last 12 months that a customer, employee, or regulator complained about? (Listen for hesitations. A slow "no" is often a "yes.")

B5. If an employee pasted your most sensitive data into a public AI tool tomorrow morning, who would find out, how, and when?

Red flag if: B1 or B2 touches EU, Illinois, or a regulated sector, and B5 has no answer. That is unmanaged exposure.

Category C: Existing Policies and Documents (5 questions, ~3 minutes)

C1. Do you have a written AI policy today? (If yes: "Can you send it to me after this call? I want to look at it.")

C2. Do you have an information security policy? Acceptable use policy for computers and internet? Data classification scheme?

C3. If a regulator, insurer, or enterprise customer asked you tomorrow for your AI governance documentation, what would you send?

C4. Who drafted your current policies? Internal, counsel, template from the internet, never written?

C5. When were your policies last reviewed? When is the next review scheduled?

Red flag if: C3 is "nothing" or "I don't know" and a trigger is already in motion (insurance, enterprise, board). That is the contract closing right there.

Category D: Stakeholder Accountability (5 questions, ~3 minutes)

D1. Who inside the company is responsible for AI today? Name them. (If the answer is "everyone" or "the leadership team," mark that as no one.)

D2. If a customer gets a bad AI-generated output that causes harm, who owns the response? Who decides whether to disclose? Who decides whether to refund or settle?

D3. Does your board know how your company uses AI? Has it been a board agenda item in the last 12 months?

D4. Who in your company has the authority to approve a new AI tool or a new AI use case? Who can veto one?

D5. If I asked your head of HR, your head of engineering, your head of sales, and your head of finance "who owns AI governance here," would they all give me the same name?

Red flag if: D1 and D4 return different names, or if D5 is "probably not." Diffuse ownership is the single biggest predictor of governance-by-PDF.

Category E: Vendor Relationships (5 questions, ~3 minutes)

E1. How many SaaS vendors do you use that have shipped an AI feature in the last 18 months? Rough count.

E2. Have any of them sent you an AI-specific addendum, DPA update, or notice of change to their terms in the last six months? Did you sign it?

E3. Do you review AI features in your SaaS tools before they go live for your team, or after?

E4. Do you have contractual rights if a vendor's AI model hallucinates, leaks your data, or produces a biased output? Do you know what those rights are?

E5. If one of your AI vendors had a data breach tomorrow, when would you find out, and what would they be obligated to tell you?

Red flag if: E2 has an unsigned addendum sitting in someone's inbox. That is the vendor addendum content angle from Part 4 converting into live work.

1.3 Governance Maturity Assessment

Four levels. Complete the read in Phase 3 of the session. Write the level in big letters at the top of the shared doc. Clients take pictures of their own level. That is the artifact that circulates inside the org.

Level 0: Unmanaged

What it looks like. No written AI policy. No AI inventory. Employees use whatever they want. Leadership has not had a formal conversation about AI risk. If asked, the answer is some variant of "we are being careful."

Immediate risk. Shadow AI data leakage is actively happening and will not be discovered until something goes wrong. No defense against a vendor AI addendum request, an insurance renewal question, or a customer contract addendum. Title VII exposure on any hiring tool. EU AI Act prohibited-practices exposure if any EU-adjacent work is happening.

Recommended next step. AI Use Inventory. Two weeks, fixed fee, produces a list of every AI tool in use with a risk tier on each. This is the only place to start. Policy without inventory is fiction.

Level 1: Reactive

What it looks like. A policy exists, usually a template downloaded from the internet or drafted by counsel without an inventory underneath it. One person has been told they own AI, usually as an add-on to their real job. No inventory. No active monitoring. Responses to AI questions are ad hoc.

Immediate risk. False security. The policy exists, which means if something goes wrong, the policy will be produced in discovery and its gaps will be the plaintiff's exhibit A. Shadow AI is still unmanaged. Vendor addenda are signed by default because no one has a review process. The policy has not been tested against a real incident.

Recommended next step. Governance gap assessment plus AI Use Inventory. Four weeks. Produces a gap list against a current-state anatomy, an inventory, and a 90-day remediation roadmap. Do not let them jump to drafting a new policy. Fix the foundation first.

Level 2: Operational

What it looks like. Policy exists and has been refreshed in the last 12 months. Inventory exists and is maintained. A named owner exists with real authority, usually a GC, CISO, COO, or head of risk. A review process exists for new AI tools. Incident response includes AI scenarios. Vendor addenda get reviewed before signing. Board has seen at least one AI report.

Immediate risk. Framework may be aligned with outdated regulatory state (pre-EU AI Act GPAI, pre-Colorado delay, pre-EO 14179). Control implementation may still be theater (human-in-the-loop without measured override rates, training completed without retention measurement). Sector-specific overlays may be missing.

Recommended next step. Governance framework refresh plus playbook build. Six to eight weeks. Updates the framework to current regulatory state, builds an operational playbook that addresses the theater risks, and produces an audit-ready evidence file.

Level 3: Production-Ready

What it looks like. All of Level 2, plus: policy is version-controlled with a changelog, review cadence is annual minimum with quarterly reviews for high-risk systems, amendment triggers are defined, incident response has been tabletop-tested, training has measurable completion and knowledge-check metrics, vendor management includes audit rights exercised at least once, board gets AI on its risk committee agenda at a fixed cadence, sector-specific overlays are addressed where applicable, and the organization is either ISO 42001 aligned or explicitly not pursuing it with a documented rationale.

Immediate risk. Drift as AI capabilities and regulations evolve. Over-reliance on a single named owner who becomes a bottleneck. Audit fatigue if the evidence file is not maintained in real time.

Recommended next step. Annual refresh engagement. One to two weeks. Verifies every element against the current regulatory and capability state, updates the matrix, refreshes the board report, and confirms the evidence file is current.

How to read borderline cases

Most SMBs at the discovery stage are Level 0 or Level 1. A small minority think they are Level 2 because they have a policy. Your job is to ask the follow-through question that reveals the truth: "When was the last time your incident response plan was exercised?" "What is the override rate on your human-in-the-loop review?" "Who on your board has read the current policy?" One of those questions usually resolves the borderline.

If the client argues with your read, do not argue back. Say: "Noted. I will write up what I see and you can push back on it in writing. That written exchange is more useful than me convincing you on the call."

1.4 Session Output Template

The post-session artifact is not a report. It is a one-page internal memo that the client can forward inside their org without editing. Format below is literal. Copy it and replace the bracketed items.

Send within 24 hours of the session, as a PDF plus a pasted-in email body. The email subject line is the artifact title.

AI Governance Diagnostic: [Client Company Name] Session date: [date] Prepared by: [your name], [your firm]

Trigger [One sentence in the client's own words from Phase 1. Example: "Your cyber insurance renewal questionnaire now includes 14 AI governance questions and is due in 45 days."]

Current maturity level Level [0, 1, 2, or 3]: [Unmanaged / Reactive / Operational / Production-Ready]

One-sentence read on why. Example: "Written AI policy exists but was drafted without an inventory, no named owner with veto authority, and shadow AI has not been audited in the last 12 months."

The three risks that matter most for your situation

1. **[Risk name].** [One sentence on what it is, specific to this org.] **If you do nothing for 90 days:** [one specific consequence, with a date if possible]. **Simplest containment move:** [one action, named owner, timeframe].
2. **[Risk name].** [Same structure.]
3. **[Risk name].** [Same structure.]

What you could do next

Three options, ordered from smallest to largest:

- **AI Use Inventory.** Two weeks. Fixed fee of $[X]. Outcome: a ranked list of every AI tool in your business with a risk tier and an owner recommendation for each.
- **Jurisdictional map and Acceptable Use Policy.** Four weeks. Fixed fee of $[X]. Outcome: a one-page map of which regulations apply to you and why, plus a six-page AUP in plain English that employees will actually read.
- **Governance framework and policy bundle.** Six to eight weeks. Fixed fee of $[X]. Outcome: a board-facing framework, an employee-facing policy, a review process, a vendor intake checklist, and an incident response playbook.

What I need from you to move forward

If you want to proceed, reply to this email with which option fits and I will send a one-page scope document by end of next business day.

If you want to think, the best thing you can do in the next seven days is [one specific, free action tied to the top risk above, for example: run the shadow AI audit worksheet or send me your current policy].

Design notes for why this template works.

1. It is one page. It gets forwarded. Internal forwards are how consulting relationships compound in SMBs.
2. It uses the client's trigger language verbatim. When the COO forwards it to the CEO, the CEO sees their own words.
3. It names the three risks specifically. Generic risk language ("you should think about AI") gets deleted. Named risks tied to their inventory get read.

4. The three follow-on options are priced at the top of the email so no one has to ask. Removing a "what will this cost" friction point converts meaningfully more sessions to contracts.
5. It ends with a specific free action, which respects clients who are not ready to buy today but may buy in 60 days when the free action surfaces something.

Practitioner Action Box

In the next seven days: build the shared live document template for the discovery session, then run the session on two non-paying test subjects.

Specifics:

- Open a Google Doc or Notion page titled "AI Governance Diagnostic: [Company Name] Template." Populate it with the five phase headers, the 26 diagnostic questions from Section 1.2 as a fill-in-the-blank list, the four-level maturity model for reference, and the three-risk structure for Phase 4.
- Run the full 60-minute session on two people: a founder friend in a relevant vertical (SaaS, professional services, staffing, light healthcare), and a peer consultant in an adjacent field (cyber, privacy, employment law). Do not pitch. Just run the session. Ask them at the end what was useful and what was not.
- After each test run, send the session output template (1.4) within 24 hours. Ask them if they would have forwarded it inside their company, and if not, why not.

You are not testing the framework. You are testing whether the output artifact circulates. If it does not get forwarded, rewrite it until it does. That artifact is the demand generation engine for every other part of this toolkit.

PART 2: OBJECTION HANDLING AND THE BUSINESS CASE

SMB owner-operators do not buy AI governance. They buy relief from a specific pressure. The objections below are not challenges to the idea of governance. They are the surface form of a buyer trying to figure out whether you are worth the money and whether now is the right time. Handle them directly, on their terms, without apology or pitch language.

2.1 The Objections You Will Hear Most Often

Format for each: the objection in the owner's voice, the honest read on what it really means, and the response you give.

"We are too small for this."

What it really means. "I don't understand why a 60-person company needs what Goldman Sachs needs."

Response. "The framework a bank runs is not what I would build for you. The risks you have are different: shadow AI by employees, one enterprise customer asking for an AI addendum, a cyber insurance renewal adding AI questions. A 60-person company needs a one-page policy, a short vendor checklist, and a named owner. Two or three weeks of work. The reason to do it now is not that you are big enough for a governance program. The reason is that the specific pressure you just described (name the trigger they said in Phase 1) has a 60-day window and you have nothing to send."

"We don't use AI that much."

What it really means. Either genuinely low usage, or the owner has no visibility into what employees and SaaS vendors are doing.

Response. "Most owners who tell me that are surprised by what we find. Last client told me they used three AI tools. We ran the audit and found 27. You do not have to trust my framing; run it yourself. Send a one-question email to your team: 'For the next two weeks, please reply to this thread with any tool you use that has AI in it.' If the count comes back low, you are right and we can stop. If it comes back higher than you expect, that is the conversation we should have."

"Our legal team (or outside counsel) is handling it."

What it really means. Either counsel has promised a policy and is four months behind, or counsel is producing a 30-page document written for a Fortune 500 client that nobody at the SMB will read.

Response. "Counsel is the right person to review and approve the policy. Counsel is usually the wrong person to draft it alone, because the document that comes out reads like a brief. I can build the draft that your team will actually follow, counsel can review it in a two-hour review and mark it up, and you end up with a policy that passes legal and gets read. Most of my engagements involve a review step with whoever your counsel is. I work with counsel, not around them."

"We are waiting to see how the regulations shake out."

What it really means. Either the owner read that the EU AI Act got delayed and concluded nothing applies, or they are using regulatory uncertainty as cover for not doing work that feels abstract.

Response. "The EU AI Act's high-risk obligations got pushed to 2027 or 2028. The prohibited practices have been in force since February 2025 and the general-purpose AI rules since August 2025. Illinois HB 3773 is in force. Texas TRAIGA is in force. NYC LL 144 is in force. Colorado went live this year. If you are waiting for full regulatory clarity before doing anything, the answer is that you are already in scope for a handful of rules. The cheapest time to get organized is before a specific customer, insurer, or plaintiff forces you to."

"We can't afford this right now."

What it really means. Sometimes true. More often the owner is comparing your fee to nothing, not to the cost of the alternative.

Response. "What does an incident actually cost you? One employee pastes a customer list into a public LLM and the disclosure goes wrong: that is a breach notification, a forensic investigation, and a customer churn event. The iTutorGroup EEOC settlement was $365,000 for a hiring tool. Air Canada lost a liability case over a chatbot giving wrong pricing. None of those are enterprise numbers; they are mid-market and SMB-scale. The question is not whether you can afford to do this. The question is what the cheapest version looks like that moves you out of the riskiest zone. That is usually a two-week inventory for four to eight thousand dollars. If that is out of reach, tell me honestly and I will give you a free self-serve version you can run in an afternoon."

"We already have an AI policy."

What it really means. They have a two-page template downloaded from the internet or drafted by counsel 18 months ago.

Response. "Good. Send it to me before our next call. I will mark it up against the current state of regulation and your actual AI use, and tell you in a page what is solid and what is exposed. No charge. If the markup shows real gaps, we talk about what comes next. If the markup shows you are in good shape, I will tell you that and we stop. Either way you end up with a free second opinion on a document that is probably overdue for a review."

This is the single most productive objection response in the toolkit. A surprising number of clients send you the policy, you mark it up, and the gaps sell the next engagement. Do not skip it.

"Won't AI governance slow down our team?"

What it really means. Founder has seen a compliance program that became a bottleneck and is worried you are selling one.

Response. "The version I build for a company your size does the opposite. It is a short policy, a vendor checklist, and a named owner. The goal is that your team knows the three things they cannot do and everything else is fine. Without that, every new AI tool becomes a debate. With that, decisions take minutes. If I ever build you something that adds friction for its own sake, fire me."

"Why should we work with you instead of a bigger firm?"

What it really means. Signaling they have talked to someone larger and the quote scared them, or they are genuinely comparing.

Response. "A bigger firm will sell you a $150,000twelve - weekengagementwithajuniorteam.Youwillendupwitha200 - pagedeliverableandasix - monthimplementation.Youprobablydonotneedthat.Isellfixed - scopeworkinthe$ 3,000 to $25,000 range, delivered in two to eight weeks, and the deliverable is short enough that your team will actually use it. If you do need the 200-page version eventually, I will tell you and hand you off. I lose a deal by doing that honestly and I gain a referral relationship."

2.2 The Business Case in Owner-Operator Language

A skeptical SMB owner has never thought about governance. Do not lead with governance. Lead with the five things they already care about. The order below matters; it is the progression from immediate pain to strategic positioning.

Liability

You are on the hook for what your AI does. Air Canada tried to argue its chatbot was a separate entity; a tribunal rejected it in an afternoon. If an AI tool you use (yours or a vendor's) tells a customer the wrong price, the wrong policy, or makes a discriminatory decision, the legal counterparty is your company. The first question in a plaintiff's discovery is "what policies did you have in place." If the answer is "none," you are paying more than you would have paid to write one.

Operational continuity

Shadow AI is a data leak waiting to happen. The single most common incident in 2025 was an employee pasting sensitive data into a public LLM. Samsung had it. Countless smaller companies have had it without making the news. One event triggers a breach notification process that takes your leadership team offline for three to six weeks. Governance is cheaper than a forensic investigation.

Vendor risk

Your SaaS vendors are shipping AI features faster than your procurement process is reviewing them. Most of your current vendor contracts do not address what happens if a model hallucinates, leaks your data, or is trained on your inputs without your explicit consent. A simple vendor intake checklist, applied to every new SaaS purchase and every AI feature release from existing vendors, closes 80 percent of this exposure. It takes two weeks to build.

Employee behavior

Your team is already using AI without telling you. Either give them a short, clear set of rules (what they can paste, what they cannot, what tools are approved) or accept that the first incident will be the first time you discuss it. Training is a 30-minute conversation, not an 8-hour course. The return on that 30 minutes is every single incident it prevents.

Competitive positioning

This is the argument that converts the skeptic. Your enterprise customers are starting to ask for your AI policy as a condition of renewal. Your cyber insurance is starting to add AI questions to the renewal questionnaire. Your largest prospects are starting to send AI addenda before signing the contract. Having a clean, short, credible governance artifact ready to send is now a sales weapon. The first company in any vertical to get this right takes market share from the ones that stall.

Close with: "You do not need to believe all five of these. You need to pick the one that matches the pressure you are under this quarter and start there."

2.3 Trigger Events

The buyers who say yes are not convinced by the business case. They are reacting to a specific event. Learn the signals. When you see one, the conversation becomes easy.

Insurance trigger

Cyber insurance renewal questionnaire adds AI governance questions. Happens annually, usually in Q3 or Q4. Broker is pushing. Questionnaire has a hard deadline. Buyer has 30 to 60 days.

Enterprise customer trigger

Largest customer sends an AI addendum to the master agreement, requests a policy review, or adds AI questions to an annual vendor review. Buyer has 30 to 45 days.

Board trigger

Board member reads something about AI risk and puts it on the agenda, or audit committee chair asks for a report. Buyer has one quarter to produce an artifact.

Regulator trigger

State AG sends an information request, or the company receives any letter mentioning AI, bias, automated decisions, or discrimination. Buyer has days, not weeks, and needs a referral to counsel plus a governance package to bolt on afterward.

Incident trigger

Employee incident (data leak, biased output, customer complaint), vendor incident (their breach, their bad output), or near-miss. Emotional window of about 30 days where the buyer will fund the work; after that the urgency fades.

Acquisition or investment trigger

Due diligence on either side of a deal asks for AI governance documentation. Deal timeline drives the buyer. 60 to 90 days is typical.

Enterprise procurement trigger

The buyer is selling to a Fortune 500 or public-sector client and the buyer's prospect is asking for ISO 42001 alignment or NIST AI RMF mapping. Buyer sees a six or seven figure deal slipping and will spend to close it.

Competitive trigger

A direct competitor publishes an AI governance statement, a trust center, or a responsible AI page. Buyer feels behind. Less urgent than the others but a reliable source of inbound.

Employee trigger

An employee at the client's company asks a pointed question in an all-hands or sends a memo about AI ethics. Happens more often in companies with technical workforces and younger teams. Often converts to a board trigger within 60 days.

Signals to watch for in discovery calls

- The phrase "our insurance," "our auditor," or "our biggest customer" in the first five minutes.
- Specific dollar amounts named unprompted ("we had a $20,000 incident last quarter").
- A forwarded email or PDF pulled up during the call.
- A named deadline on the client's side of the table.
- Tense relationship with counsel referenced ("legal is taking forever").

Any two of those in a single discovery call means the contract is already in motion; your job is to not get in its way.

Practitioner Action Box

In the next seven days: write one email template per trigger type (nine total), kept short enough to paste into a response to an inbound inquiry.

Each email has the same skeleton: one sentence naming the trigger in the buyer's language, one sentence on what the first meeting covers, three bullet points of fixed-scope options with fees, and a one-sentence close asking them to reply with which option fits.

Save them in a folder called "Trigger Responses." When an inbound inquiry lands that matches a trigger, you paste the relevant one in 90 seconds, personalize two or three lines, and send. Response time compounds. Most consultants reply in 48 hours with a generic "let me know when you want to chat." A 90-minute reply with specific pricing and fit wins more engagements than any other single move.

PART 3: IMPLEMENTATION ROADMAP FOR CLIENTS

The engagement does not end at the signed contract. The client has to implement. The tiered roadmap below is what you walk them through in the kickoff, in the 30-day check-in, and in the closing handoff. It gives them a path from "we just started" to "we lead on this in our industry" without over-promising and without making the current stage feel broken.

Three tiers. Each is self-contained. A client can live at any tier indefinitely if that is the right level for their risk profile. Most SMBs should live at Tier 2 and only move to Tier 3 if a specific pressure (public company obligation, regulated sector expansion, enterprise deal requirement) forces it.

3.1 Tier 1: Minimum Viable Governance

Who it is for. 20 to 150 employees, no regulated sector, no EU customer base, no hiring-tech primary business. Typical trigger: insurance, first enterprise customer, founder read an article.

The goal. Not exposed. Able to produce a coherent artifact on 48 hours notice. Not leading, not bleeding.

Key deliverables.

1. One-page AI Use Inventory, updated quarterly, owned by one person, listing every AI tool in use with a risk tier on each.
2. Six-page Acceptable Use Policy in plain language. Covers what data employees can paste into what tools, what uses are prohibited, who to ask when in doubt, what happens if they break the rules.
3. One-page jurisdictional applicability map listing the regulations that apply based on customer and employee geography plus sector, with the trigger for each.
4. Two-page vendor intake checklist applied to any new SaaS or any AI feature release from an existing vendor.
5. One-page incident response card covering the "boring incident" (data paste, biased output, wrong customer answer) with named owners, first-hour steps, and notification triggers.
6. One named owner, 2 to 4 hours a month, with a monthly 30-minute review of the inventory and any incidents.

Estimated time to implement. Three to six weeks elapsed, roughly 40 to 80 hours of combined practitioner and client work.

Common blockers.

- No one wants to own it. Resolve by making it explicit that the owner is the person who answers when the insurer asks, not the person who does all the work.
- Inventory process stalls because employees are embarrassed to list shadow tools. Resolve by framing the inventory as amnesty: "Tell us everything you use by end of the week, no consequences. After that date, unknown tools are violations."
- Policy review gets stuck in legal for weeks. Resolve by pre-agreeing with counsel on a two-hour review slot and a specific scope (legal reviews for regulatory alignment only, not rewrite).

Signs the organization is ready for Tier 2.

- Inventory is maintained without being asked.
- Owner is recognized by name by employees in other departments.
- Policy gets referenced in a real decision at least once a quarter.
- A vendor addendum or AI feature release was reviewed before deployment, not after.
- The company has grown past 150 employees, added an EU customer, or entered a regulated adjacency.

If any three of those are true, the Tier 2 work pays for itself.

3.2 Tier 2: Operational Governance

Who it is for. 150 to 500 employees, or smaller companies with regulated-sector exposure (healthcare, banking, insurance, lending, hiring-primary, education). Typical trigger: enterprise customer contract, board mandate, regulator inquiry, or growth into a new jurisdiction.

The goal. Governance runs as a process, not a project. The company can demonstrate control, evidence, and cadence to an external counterparty.

Key deliverables.

1. Full Governance Framework (8 to 15 pages) with principles, risk posture, decision rights, risk tiering, escalation paths.

2. Policy (10 to 20 pages) with enforceable rules, integrated with existing handbook and information security policy.
3. Playbook (30 to 50 pages) with: vendor intake process, use-case approval workflow, risk assessment template, human oversight standards per tier, training curriculum and cadence, incident response runbooks for three named scenarios, audit evidence checklist.
4. AI governance committee charter with membership, cadence, authority, and decision log template. Meets monthly.
5. Annual refresh cycle. Full policy review on a fixed calendar date. Quarterly use-case registry review. Triggered reviews on specific events (new regulation, new high-risk use case, incident, major vendor change).
6. Evidence file. Living document that collects: the inventory, the training completion records, the vendor review records, the incident log, the committee meeting minutes, the decision log. Organized in a way that can be handed to an auditor, insurer, or regulator on 48 hours notice.
7. Training program. 30-minute onboarding for all new hires, 15-minute annual refresh for existing staff, role-based deep dive for anyone whose work involves customer-facing AI, hiring decisions, or high-risk use cases.
8. Board reporting cadence. One report per quarter to the audit or risk committee. Template provided.

Estimated time to implement. Eight to sixteen weeks elapsed. 120 to 300 hours of combined work. Ongoing steady-state is 15 to 30 hours per month for the named owner.

Common blockers.

- Committee theater. Committee exists, meets, produces minutes, never blocks anything. Resolve by empowering the committee to veto deployments and measuring the veto count as a health metric (zero vetoes in a year is a red flag).
- Training completion drops over time. Resolve by tying completion to a quarterly business process (commission release, bonus eligibility, performance review).
- Evidence file rots. Resolve by assigning ownership to one person who reviews the file monthly against a checklist, not to "the committee."
- Sector overlay conflicts with base policy. Resolve by structuring the playbook as a base plus sector-specific annexes rather than rewriting the base for each sector.

Signs the organization is ready for Tier 3.

- External counterparties (insurers, enterprise customers, regulators) have reviewed and accepted the evidence file without remediation requirements.
- Incident response has been exercised in a tabletop within the last 12 months.
- Training completion is above 95 percent with measured knowledge retention.
- At least one use case has been declined or restructured by the committee.
- The company is pursuing ISO 42001 certification, is subject to board-level fiduciary expectations (public company, regulated sector leader, public-sector contract), or wants to use AI governance as a market differentiator.

If those are true, Tier 3 is not optional, it is overdue.

3.3 Tier 3: Mature Governance

Who it is for. 500+ employees, regulated-sector leader, public company, significant public-sector contract exposure, or mid-market company using AI governance as a product differentiator.

The goal. The organization leads publicly on AI governance. It can explain its program to regulators, customers, auditors, and the press without preparation. It contributes to industry standards rather than just consuming them.

Key deliverables.

1. Everything in Tier 2, maintained at a higher cadence (policy review twice yearly minimum, quarterly board reporting, monthly committee).
2. ISO 42001 alignment, with a documented decision on whether to pursue formal certification. If pursuing: certification roadmap, gap assessment against Annex A controls, third-party audit scheduled.
3. NIST AI RMF alignment at Tier 3 maturity (GOVERN, MAP, MEASURE, MANAGE functions all operationalized with measurable outcomes).
4. Public-facing trust artifacts. Published responsible AI page, model cards for customer-facing AI systems, annual transparency report, data handling disclosures.
5. Red-team or adversarial testing program for every customer-facing LLM deployment, with results tied to the use case approval process.
6. Third-party audits on a fixed cadence. At minimum: annual internal audit, every 18 to 24 months external audit of the governance program.
7. Cross-functional governance talent. Dedicated AI governance lead (full-time), AI council with senior-level participation, named AI governance roles in legal, security, product, and HR.

8. Contribution to external standards or industry bodies. Membership in FS-ISAC, IAPP AI Governance Center, state working groups, or industry-specific codes. Published thought leadership from at least one named executive.

Estimated time to implement. 12 to 24 months elapsed from Tier 2 mature state. Full-time headcount plus program budget in the low-to-mid six figures annually.

Common blockers.

- Leadership commitment erodes if the governance program is perceived as slowing down competitive AI shipping. Resolve by publishing quarterly metrics showing that governed deployments are faster (not slower) than ungoverned ones, because the vendor review, risk assessment, and approval workflow have become routine.
- Third-party audit produces findings that require expensive remediation. Resolve by running internal audits aggressively first; surprises in external audits are governance program failures.
- The named AI governance lead becomes a single point of failure. Resolve by documenting every process to the level where a successor could pick it up in 30 days.
- Public trust artifacts create new liability surface if they over-claim. Resolve by having counsel review every public statement and using "aligned with" language, never "compliant" or "certified" without verifiable evidence.

3.4 Staying Relevant as AI and Regulation Evolve

A governance program that ships on a Tuesday and becomes shelf material by the following quarter is the most common failure mode. Six built-in mechanisms keep the program alive.

Versioning and changelog at the top of every document

Every policy, framework, and playbook opens with: current version number, effective date, approver, changelog. Every change is logged with a one-sentence reason. The changelog is how you prove to an auditor that the program is alive.

Amendment triggers defined in the policy itself

The policy names the events that trigger an out-of-cycle review: new regulation in a jurisdiction where you operate, new high-impact use case, any severity-2-or-higher incident, major model version change from a core vendor, acquisition or divestiture, turnover in the named owner role. When a trigger fires, the review happens within 30 days.

A fixed review cadence that does not require anyone to remember

Annual full review of all documents on a specific calendar date (usually the anniversary of the original adoption). Quarterly review of the use-case registry and high-risk systems. Monthly owner check-in with the inventory. Put the dates in the corporate calendar with recurring invites and named attendees.

A source-watching process, not just document-watching

The sources the policy cites (EU AI Act, NIST AI RMF, relevant state statutes, relevant vendor policies) are tracked for change. When a source changes, the policy is flagged for review. This is where practitioner-level tooling pays off: an RSS feed or a scheduled scraper against the top 20 sources, dumping into a review queue.

Sunset clauses on every vendor and every control tied to a specific model version

Every vendor relationship has an expiration date in the policy's vendor register with a re-review trigger. Every control tied to a specific model version (GPT-4, Claude 3.5 Sonnet) has a review date tied to that model's deprecation or major version change. This prevents stale references from living on past their relevance.

A near-miss reporting norm

Employees report near-misses (something almost went wrong, someone almost pasted the wrong data) without consequence. Each near-miss is logged. Patterns get surfaced in the monthly review. This is the single most effective early warning system a governance program has, and almost no SMB has one.

Practitioner Action Box

In the next seven days: build a single-page "Tier Progression Map" that you will hand to every client in every kickoff.

The artifact has three columns, one per tier. Each column has: name, who it is for in one sentence, the five or six deliverables listed tersely, the time to implement, and the single signal that means "ready for the next tier." On the back of the page: the six mechanisms in 3.4 that keep a governance program alive.

This is the artifact that sets the client's expectations before you send the scope document. Clients who see the map understand why you are not recommending Tier 3 for a 50-person company; they understand why the Tier 1 deliverable list is short; and they understand what they are buying when you propose a Tier 2 engagement. Ambiguity about scope is the single largest source of client dissatisfaction in the middle tier. The map eliminates it.

PART 4: CONTENT STRATEGY AND EDUCATIONAL ANGLES

4.1 The Most Misunderstood Concepts in AI Governance

SMB owner-operators are not stupid. They are busy, under-resourced, and drowning in vendor marketing that conflates very different things. The result is a set of predictable misreads that show up in almost every discovery call. Naming these cleanly is the fastest way to earn trust in the first ten minutes of a conversation, because owners recognize the confusion the moment it is spoken back to them.

1. **AI governance is not an IT project.** It is a decision-rights problem. The hardest questions (who can approve a tool, who owns the output, what a customer was promised) live in operations, HR, legal, and sales long before they touch IT.

2. **A policy is not a control.** A policy is a statement of intent. A control is the mechanism that makes the policy true when nobody is looking. Most SMBs have the first without the second and are surprised when incidents still happen.

3. **Risk tiering is not the same as model accuracy.** A 98% accurate model used to decide who gets fired is higher risk than a 70% accurate model used to summarize meeting notes. Risk lives in the use case, not the benchmark.

4. **Vendor compliance is not your compliance.** A SOC 2 report from your AI vendor tells you their house is in order. It tells a regulator nothing about how your employees actually used the tool to make a decision about a real customer.

5. **The EU AI Act is not "only for Europe."** If you sell to an EU customer, employ a remote worker in the EU, or process data from an EU resident, relevant articles reach you. US companies are already receiving AI addendum requests from European buyers.

6. **Shadow AI is already in your company.** The question is not whether employees are using ChatGPT, Claude, Gemini, Copilot, or Notion AI on company data. They are. The question is whether you know what they are pasting in.

7. **A human in the loop is not the same as human oversight.** A human clicking "approve" on 400 AI-generated decisions per day is a rubber stamp, not oversight. Oversight requires the human to have the authority, time, and information to actually override the machine.

8. **Incident response for AI is different from IT incident response.** A traditional breach is about data that left. An AI incident is often about a decision that was made: a wrongful denial, a biased screening, a hallucinated claim to a customer. The forensics, the notification logic, and the remedy all look different.

9. **Data retention policies do not auto-apply to prompt logs.** Your 90-day email retention rule says nothing about the two years of employee prompts sitting in a vendor's logging system. Every AI tool creates a new data store that your existing policies were not written to cover.

10. **You cannot opt out of AI governance by banning AI.** A blanket ban drives usage underground, creates deniability for leadership, and leaves the company with all the risk and none of the visibility. Bans are the least governed state, not the most.

11. **"We are too small to be a target" is not a risk assessment.** Regulators, plaintiffs' lawyers, and insurance carriers do not size-gate their interest. A 40-person staffing firm that uses AI to screen applicants is exactly the kind of entity state AGs are writing rules for.

12. **Training is not a control either.** A 30-minute annual video on "responsible AI use" produces a signed acknowledgment. It does not produce behavior change. Treat training as the lowest tier of the control stack, never the whole stack.

4.2 What SMBs Actually Search For

These are the queries owners, HR leads, and office managers actually type. They are often misspelled, panicked, and typed at 11pm after a board email or a news clip. Content that matches this register converts. Content that matches compliance vendor language does not.

Cluster 1: "I just heard about a law and I'm worried"

Intent: the owner saw a headline, a LinkedIn post, or a chamber-of-commerce email and wants to know if it applies to their company in the next sixty seconds.

- does the colorado ai act apply to small business
- colorado ai act 2026 what do i need to do
- illinois ai video interview law penalties
- nyc bias audit ai hiring how much does it cost
- texas ai law for employers
- california ai disclosure rule small business
- do i need to comply with eu ai act if i only sell in the us

Cluster 2: "My employees are using ChatGPT and I don't know what to do"

Intent: the owner knows something is happening and wants a practical answer, not a philosophy lecture.

- can i let employees use chatgpt at work
- chatgpt at work policy template free
- how do i stop employees putting client data in chatgpt
- is it legal for my staff to use ai without telling clients
- employee used ai to write a client email what now
- how to audit what ai tools my employees are using

Cluster 3: "Something went wrong, help"

Intent: an incident already happened. The owner is looking for a playbook, not an education.

- employee used ai to screen candidates can i be sued
- ai made a mistake in a customer quote do i have to honor it
- chatgpt hallucinated a legal citation what do i do
- fired employee for misusing ai can they sue
- can i fire someone for using ai at work
- client found out we used ai to write their report

Cluster 4: "The vendor sent me a contract and something feels off"

Intent: owner or office manager is staring at an AI addendum, MSA, or DPA they do not understand.

- ai vendor contract red flags

- what is an ai addendum in a saas contract
- does our vendor train on our data
- how to read a dpa for an ai tool
- ai indemnification clause what to look for
- vendor says they use ai to improve their product what does that mean for us

Cluster 5: "Insurance, liability, and the board are asking"

Intent: a renewal, a board meeting, or a bank covenant triggered the question. The owner needs defensible language by a specific date.

- does general liability insurance cover ai mistakes
- cyber insurance ai exclusion 2026
- how to answer ai questions on insurance renewal
- what to tell the board about ai risk
- ai liability small business

Cluster 6: "Do I even need a policy?"

Intent: the owner wants permission to either do the work or skip it. They are looking for a clear yes or no.

- does a 50 person company need an ai policy
- minimum ai governance for small business
- smb ai policy cost
- cheapest ai policy template

Cluster 7: "What does this actually cost?"

Intent: the owner is trying to budget a line item and has been quoted wildly different numbers by consultants, law firms, and SaaS vendors.

- how much does ai governance cost for a small company
- ai compliance consultant fees
- ai risk assessment price small business
- do i need a fractional ai officer

4.3 Five Underserved Content Angles

Current AI governance content is dominated by two voices: big-four firms writing for Fortune 500 audit committees, and SaaS vendors writing landing pages to sell a dashboard. Neither speaks to a 60-person company whose owner wears four hats. These five angles fill the gap.

Angle 1: "The Four Documents Every SMB Actually Needs (and Nothing Else)"

Gap it fills: Every framework on the market (NIST AI RMF, ISO 42001, the EU AI Act) is written as a universe of artifacts. SMBs need the minimum viable set, not the full catalog. No one has published the short list with opinions.

Moment of need: Owner has just been told by counsel, a buyer, or a board member that they "need AI governance" and is trying to figure out the smallest defensible response before the next meeting.

Format: A 1,800 word article plus a downloadable one-page index of the four documents. The index is gated behind an email, the article is not.

First paragraph sketch: "If a regulator, a plaintiff's lawyer, or your largest customer walked into your office tomorrow and asked to see how you govern AI, you would need to hand them four documents. Not forty. Four. An acceptable use policy that tells employees what they can and cannot paste into which tools. A tool inventory that lists every AI system in use and who owns it. A decision log that captures the consequential calls and who signed off. And an incident record showing that when something went sideways, you noticed, acted, and learned. Everything else in the governance literature is a supporting document. If you do not have those four, start there. If you have those four, you are ahead of most companies your size."

Angle 2: "The Afternoon Shadow AI Audit"

Gap it fills: Every consultant talks about shadow AI. Nobody has published a concrete, 3-hour procedure that a non-technical operator can actually run without buying software.

Moment of need: Owner suspects staff are using tools they have not approved and wants a fast, non-accusatory way to find out before the next board meeting or insurance renewal.

Format: A printable checklist plus a Loom-style walkthrough. Ships as a PDF with fillable fields so an office manager can complete it without training.

First paragraph sketch: "You do not need a security team, a SaaS discovery tool, or a consultant to find out which AI tools your company is actually using. You need three hours, a spreadsheet, and permission to ask uncomfortable questions. This audit walks you through a procedure a 40-person company can run on a Tuesday afternoon. It will not catch everything. It will catch enough to make the next conversation with your insurance carrier, your biggest customer, or your board an honest one instead of a hopeful one."

Angle 3: "How to Read an AI Vendor Addendum Without a Lawyer in the Room"

Gap it fills: Owners and office managers are receiving AI addenda from every SaaS vendor they already use. They cannot afford to send every one to outside counsel. Current content either dismisses the risk or treats every clause as equally dangerous.

Moment of need: An existing vendor just pushed an updated DPA or AI addendum with a 30-day accept-or-terminate clock. The owner has to decide.

Format: A teardown article that walks through a real (redacted) addendum clause by clause, flagging the three clauses that matter and the eight that do not. Pairs with a one-page triage checklist.

First paragraph sketch: "Your CRM vendor just sent you a 14-page AI addendum and gave you 30 days to sign it. Your lawyer charges $450 an hour. You have 19 other things to do this week. Here is the truth: three clauses in that document matter, and the other eleven are boilerplate you can sign without losing sleep. This piece walks through a real vendor addendum, names the clauses, and tells you what to push back on, what to accept, and what to walk away from."

Angle 4: "The Boring Incident Playbook"

Gap it fills: AI incident response content either borrows wholesale from cybersecurity (wrong model) or invents elaborate frameworks no small team will execute. A boring, short, operator-grade playbook does not exist publicly.

Moment of need: An incident just happened. An employee used AI on a customer matter and something went wrong. The owner has hours, not weeks, to respond.

Format: A template playbook, 4 pages, structured as a checklist with decision gates. Released as a Google Doc copy and a printable PDF. Sits behind an email.

First paragraph sketch: "The first hour after you discover an AI incident is the hour that will be reconstructed later by a lawyer, an insurance adjuster, or a reporter. What you do in that hour matters more than any policy you wrote before it. This playbook is boring on purpose. It assumes you are tired, your team is anxious, and your phone is already ringing. It gives you the five things to do in the first hour, the three people to call, the one document to start writing, and the one thing never to do. Print it. Put it in the same binder as your fire evacuation plan."

Angle 5: "What to Say When Your Board Asks About AI Risk"

Gap it fills: Small company CEOs are being asked by boards, investors, and bank relationship managers to present on AI risk. They have no template, no benchmarks, and no language. Big-four board decks are overkill and scare the audience.

Moment of need: A board meeting is scheduled, an investor update is due, or a bank covenant review is on the calendar. The CEO has a week to prepare.

Format: A 5-slide template deck with speaker notes, plus a 900 word companion article explaining what each slide answers and the three questions board members actually ask.

First paragraph sketch: "Your board does not want to hear about the NIST AI Risk Management Framework. They want to know three things: are we exposed, what are you doing about it, and how will I know if it gets worse. This article gives you a five-slide deck, a script for each slide, and the three follow-up questions a board member is almost certain to ask. It is built for a 45-person company with a part-time CFO and a board that meets quarterly, not for a public company audit committee."

4.4 A 90-Day Content Arc

Thirteen weeks. One anchor piece, one supporting piece, and three to five social commentaries per week. The arc builds from "you are not crazy, this is confusing" (week 1) to a flagship toolkit launch (week 12) to a retrospective and roadmap (week 13). Distribution is LinkedIn first, X second, newsletter third, with SEO as a compounding second-order benefit.

Week 1: Establish the diagnostic frame

- **Anchor:** Article, "Why Your AI Governance Problem Is Not an AI Problem." Targets: owner who has been told to "do something about AI." Channels: LinkedIn long-form, newsletter launch issue, cross-posted as X Article.

- **Supporting:** Short social posts unpacking each of the 12 misunderstood concepts, one per day across LinkedIn and X.

Week 2: Name the shadow

- **Anchor:** Article, "The AI Tools Your Employees Are Using Right Now (and How to Find Out Without Starting a Fight)." Targets: HR lead, office manager. Channels: LinkedIn, newsletter.
- **Supporting:** X thread, "Six questions to ask your team on Monday."

Week 3: Ship the first tool

- **Anchor:** Checklist release, "The Afternoon Shadow AI Audit." Gated PDF, fillable. Targets: owner-operator. Channels: LinkedIn post with drop link, newsletter exclusive early access, X announcement.
- **Supporting:** Case note, anonymized, from a prior client engagement where the audit surfaced three tools nobody knew about.

Week 4: State law reality check

- **Anchor:** Article, "Colorado, Illinois, Texas, NYC: What Actually Applies to a US SMB in 2026." Targets: owner, HR lead. Channels: LinkedIn, newsletter, SEO primary.
- **Supporting:** One-slide visual per state, carousel format, LinkedIn + X.

Week 5: The four documents

- **Anchor:** Article, "The Four Documents Every SMB Actually Needs (and Nothing Else)." Targets: owner. Channels: LinkedIn long-form, newsletter, X Article.
- **Supporting:** Release a one-page index of the four documents as a gated download.

Week 6: Vendor contracts

- **Anchor:** Teardown article, "How to Read an AI Vendor Addendum Without a Lawyer in the Room." Walks through a redacted real contract. Targets: owner, office manager. Channels: LinkedIn, newsletter, X teardown thread.
- **Supporting:** One-page triage checklist.

Week 7: Live session

- **Anchor:** 45-minute live teardown on LinkedIn Live or a webinar platform: "Read This Vendor Addendum With Me." Invites three subscribers to bring a real (redacted) contract. Targets: owner, operations lead. Channels: LinkedIn event, newsletter, recording posted as follow-up.
- **Supporting:** Post-event recap article summarizing the three patterns that came up across all three contracts.

Week 8: Incidents

- **Anchor:** Article, "The Boring Incident Playbook." Targets: owner, any operator who has ever had an incident. Channels: LinkedIn, newsletter, X Article.
- **Supporting:** Release the 4-page template playbook as a gated PDF.

Week 9: Insurance and the board

- **Anchor:** Article, "Your Cyber Insurance Renewal Is Going to Ask About AI. Here Is What to Say." Targets: CFO, owner, office manager handling renewals. Channels: LinkedIn, newsletter, SEO.
- **Supporting:** Short post, "The three questions your carrier will ask and the three they should."

Week 10: Case study

- **Anchor:** Long-form case study, anonymized: "How a 60-Person Staffing Firm Handled an AI Screening Complaint in 72 Hours." Targets: owner, HR director. Channels: LinkedIn long-form, newsletter, X Article.
- **Supporting:** Pull-quotes and one-slide visuals on LinkedIn + X.

Week 11: The board deck

- **Anchor:** Article + template release, "What to Say When Your Board Asks About AI Risk." Includes 5-slide template deck. Targets: CEO, founder, fractional CFO. Channels: LinkedIn, newsletter, X thread.
- **Supporting:** Short video or Loom walkthrough of the deck.

Week 12: Flagship artifact launch

- **Anchor:** "The SMB AI Governance Toolkit." Bundles the four documents index, shadow AI audit, vendor addendum checklist, incident playbook, and board deck template into one downloadable package. Targets: every prior reader. Channels: LinkedIn announcement, newsletter exclusive week, X announcement thread, paid promotion optional.

- **Supporting:** Three-post teaser sequence in the days before launch.

Week 13: Retrospective and roadmap

- **Anchor:** Article, "Ninety Days of Writing About AI Governance: What the Inbox Taught Me." Pulls the three most common reader questions from the prior 12 weeks and answers each. Targets: the full audience. Channels: LinkedIn, newsletter, X Article.
- **Supporting:** Announce the next 90-day arc theme (likely: making the toolkit operational, moving from documents to behaviors).

Practitioner Action Box

In the next seven days: write and publish the Week 1 anchor article, "Why Your AI Governance Problem Is Not an AI Problem," as a LinkedIn long-form post and the launch issue of the newsletter. Keep it to 1,400 words. Do not gate it. Do not launch a toolkit, a landing page, or a lead magnet alongside it. Just publish the article and pin it to the top of the LinkedIn profile.

This matters more than the other ten things on the list because the entire 90-day arc depends on establishing a diagnostic voice that is visibly different from compliance-vendor content and big-four framework content. The first piece sets the frame; every subsequent artifact (the audit, the four documents, the incident playbook) lands harder because readers already know the author is the person who reframed the problem correctly on day one. Building the toolkit first, or the landing page first, or the email automation first, inverts the sequence and produces assets nobody trusts yet. The cheapest, highest-leverage move this week is one honest article that names what owners are actually confused about and refuses to sell them anything at the end of it.

PART 5: THE AI GOVERNANCE AGENT: REQUIREMENTS AND DESIGN

The governance agent sits inside agentsHQ as a named crew with its own skill, its own retrieval scope, and its own review gates. It does not generate policy from first principles. It retrieves from a curated, versioned knowledge base, applies a structured reasoning protocol, and emits artifacts that cite their sources down to the article or paragraph level. This part defines what the agent must know, how it must reason, who it serves, how it can fail, and the smallest version that earns its keep.

5.1 Knowledge the Agent Must Hold

The knowledge base is structured in four tiers. Tiers are stored as separate Supabase tables with shared schema plus tier-specific metadata, and each record carries a `source_version`, `retrieved_at`, `jurisdiction`, `effective_date`, and `superseded_by` field so the agent can refuse to cite anything stale.

Tier A: Primary regulations and statutes

Stored as full text plus structured breakdown by article, section, and subsection. Each clause is chunked at the smallest legally meaningful unit, embedded, and indexed alongside a plain-language summary written by Boubacar and reviewed before promotion. Specifically:

- **EU AI Act Regulation (EU) 2024/1689.** Articles 5 (prohibited practices), 6 and Annex III (high-risk classification), 9 through 15 (risk management, data governance, technical documentation, record-keeping, transparency, human oversight, accuracy and robustness), 16 through 29 (provider and deployer obligations), 50 (transparency for interacting systems), 52 (GPAI), and the staged application dates running from 2 February 2025 through 2 August 2027.
- **NIST AI RMF 1.0** (January 2023) structured by the Govern, Map, Measure, Manage functions with each subcategory stored as a distinct record, plus the **NIST AI 600-1 Generative AI Profile** cross-walked to the core RMF functions.
- **ISO/IEC 42001:2023** AI management system clauses, stored as a control catalog cross-referenced to NIST RMF and the EU AI Act technical documentation requirements.
- **Colorado SB 24-205** (Colorado AI Act) with the consequential decision framework, duty of reasonable care, and the 1 February 2026 effective date.
- **Texas TRAIGA (HB 149)** provisions on disclosure, prohibited uses, and the sandbox program.
- **Illinois HB 3773** amending 820 ILCS 42 on AI use in employment decisions, effective 1 January 2026, with the notice and anti-discrimination provisions.
- **NYC Local Law 144** on automated employment decision tools, bias audit requirements, and candidate notice.
- **Utah SB 149** Artificial Intelligence Policy Act, disclosure duties and the Office of AI Policy safe harbor.
- **California SB 53** (Transparency in Frontier AI Act) and **AB 2013** training data transparency, with the 1 January 2026 applicability thresholds.
- **Federal Executive Order 14179** on removing barriers to American leadership in AI and the rescission of prior executive orders.

- **OMB Memoranda M-25-21** (accelerating federal use of AI) and **M-25-22** (responsible AI procurement).
- **EEOC technical assistance** on Title VII and AI-driven selection procedures.
- **FTC enforcement actions** including the Rite Aid facial recognition settlement, Rytr, and the DoNotPay settlement as precedent for Section 5 application to AI claims.
- **ONC HTI-1 final rule** with the FAVES attributes (fair, appropriate, valid, effective, safe) and decision support intervention disclosure.
- **SR 11-7** Federal Reserve guidance on model risk management and **OCC Bulletin 2025-26** on risk management of AI in banking.

Updates: Tier A is updated on change detection. Each source URL is watched by a Firecrawl scheduled scrape, diffs are routed to a human review queue, and no change enters the active retrieval index until Boubacar approves the new version and marks the prior version `superseded_by`.

Tier B: Standards and frameworks

Voluntary but widely adopted documents that shape what "reasonable" looks like. Stored as control catalogs with crosswalks, not as free text.

- NIST SP 800-53 Rev. 5 selected control families relevant to AI systems (AC, AU, CA, RA, SA, SI).
- NIST SP 800-218 SSDF and the forthcoming AI-specific secure development supplement.
- ISO/IEC 23894 AI risk management guidance and ISO/IEC 5338 AI system lifecycle.
- IEEE 7000 series on ethically aligned design, with IEEE 7010 wellbeing metrics and IEEE 7003 algorithmic bias.
- Sector overlays: HHS AI strategy for healthcare, FINRA Regulatory Notice 24-09 on generative AI, FDA draft guidance on AI/ML-enabled device software functions, FERPA and Department of Education guidance on AI in schools, ABA Formal Opinion 512 on generative AI and lawyer ethics.
- MITRE ATLAS adversarial threat matrix for AI systems.

Updates: Quarterly refresh cycle. New editions are flagged when a standards body publishes a change notice. Crosswalks are regenerated whenever a Tier A source shifts.

Tier C: Vendor acceptable use policies and model cards

Stored as dated snapshots with a diff log so the agent can say "as of the April 2026 version" rather than citing a moving target.

- OpenAI Usage Policies, API data usage terms, enterprise privacy commitments, and model-specific system cards for GPT-4o, GPT-4.1, and o-series reasoning models.
- Anthropic Usage Policy, Commercial Terms, Acceptable Use Policy, and Claude model cards with the Responsible Scaling Policy version in effect.
- Google Generative AI Prohibited Use Policy, Gemini API terms, Vertex AI data governance, and the Gemini model cards.
- Microsoft Azure OpenAI Service code of conduct, Copilot commercial data protection terms, and the Microsoft Responsible AI Standard v2.
- AWS Responsible AI Policy, Bedrock service terms, and foundation model cards hosted via Bedrock.
- Meta Llama community license, acceptable use policy, and the Llama model cards.
- SaaS AI addenda from the top 20 tools a 50 to 250 person SMB typically runs: Notion AI, Slack AI, Zoom AI Companion, HubSpot Breeze, Intercom Fin, Salesforce Einstein Trust Layer, Atlassian Intelligence, Asana AI, Grammarly Enterprise, Canva AI, GitHub Copilot, Microsoft 365 Copilot, Google Workspace Gemini, Zoho Zia, Monday.com AI, ClickUp Brain, Gong AI, Zendesk AI, Drift AI, and Loom AI.

Updates: Watched weekly. Vendor policy pages change often and silently. Change detection is done by content hash and the diff is attached to the record; the prior version is retained for a minimum of 24 months.

Tier D: Exemplars and named failure cases

Short, dated case files. Each one stores the facts, the legal or reputational outcome, the lesson, and the specific clause or control that would have prevented it.

- **Samsung semiconductor code leak (April 2023).** Engineers pasted source code into ChatGPT. Trigger for enterprise data loss prevention and prompt-level egress controls.
- **Moffatt v. Air Canada (2024, BC Civil Resolution Tribunal).** Chatbot misstated a bereavement refund policy; Air Canada was held liable. Trigger for AI-generated customer statement review and disclaimer boundaries.
- **EEOC v. iTutorGroup (2023).** $365K settlement for age-discriminatory hiring algorithm. Trigger for bias audit and Title VII disparate impact testing before deployment.

- **McDonald's Paradox.ai McHire breach (2025).** 64 million applicant records exposed via a 123456 admin password on an AI hiring chatbot. Trigger for vendor security due diligence and credential hygiene on AI SaaS.
- **Deloitte Australia refund (2025).** AU$440K refund after a government report was found to contain AI-hallucinated citations. Trigger for human expert review gate on any AI-assisted deliverable that leaves the building.
- **Rite Aid FTC settlement (December 2023).** Five-year ban on facial recognition in retail after disparate false positives. Trigger for biometric use case escalation.
- **Mata v. Avianca (2023).** Lawyers sanctioned for ChatGPT-fabricated case citations. Trigger for mandatory citation verification in any legal or regulated output.
- **Clearview AI cumulative enforcement.** FTC, UK ICO, Italian Garante, French CNIL. Trigger for biometric template sourcing and lawful basis.

Updates: Case log updated monthly. New entries require a primary source (court filing, regulator press release, or verified SEC disclosure) before they are admitted.

5.2 Reasoning Capabilities

The agent performs four structured reasoning moves. Each move is a discrete tool in the CrewAI crew, with typed inputs, typed outputs, and a retrieval contract that forces it to cite.

1. Applicability analysis

Input. A company profile JSON object: headcount, revenue band, states of operation, countries of operation, industries, use cases, data types processed, customer geography, employee geography.

Process. The agent queries Tier A by jurisdictional match, headcount threshold, revenue threshold, and data-type match. It returns a ranked applicability matrix.

Output. A table with one row per regulation. Columns: regulation name, applies (yes / no / conditional), trigger clause and article reference, effective date, what the company would have to do. Every row carries a citation to the exact clause and the retrieval timestamp.

2. Risk tiering

Input. A use case description with at least: purpose, population affected, inputs, outputs, decision type (advisory, automated, consequential), reversibility, data classes touched.

Process. The agent applies the EU AI Act Annex III high-risk categories, the Colorado SB 24-205 consequential decision definition, the NIST RMF impact and likelihood rubric, and any sector overlay (ONC HTI-1 for clinical decision support, SR 11-7 for model use in banking).

Output. A tier label (Prohibited, High, Limited, Minimal), the specific regulatory anchor for the label, the three highest-ranked harms, and a recommended control baseline that feeds into the next move.

3. Control mapping

Input. A risk tier plus the company profile.

Process. The agent pulls from Tier B control catalogs and maps to NIST AI RMF subcategories, ISO/IEC 42001 clauses, and the relevant policy sections. It filters out controls that do not apply at the company's size (no board-level AI committee for a 45-person company, for example) and promotes the minimum viable control set.

Output. A control register: control ID, control statement, owning role, evidence required, policy section where it lives, and the regulation or standard it traces to. This is the scaffold for the artifacts in 5.5.

4. Gap analysis

Input. An existing policy document (PDF, DOCX, or Notion page) plus the company profile.

Process. The agent chunks the document, extracts the implicit control statements, runs them through an embedding match against the current control register produced for this company, and flags controls that are missing, outdated (refer to superseded regulations), vague (no owner, no evidence, no trigger), or inconsistent (two sections contradict).

Output. A gap register with three columns: control expected, status (present / missing / outdated / vague), and remediation sentence that can be pasted into the policy. Each finding cites the controlling source and the paragraph in the existing policy where the gap sits.

5.3 User Journeys

Journey 1: First-time builder

User. Priya, Head of Operations at a 50-person US SaaS company headquartered in Austin. Customers are US mid-market. The team uses ChatGPT Enterprise, GitHub Copilot, Notion AI, and Gong. No AI policy exists.

Step 1. Priya opens the agent in Notion and types: "We have no AI policy. We use ChatGPT Enterprise, Copilot, Notion AI, Gong. 50 people, Texas HQ, US customers only, B2B SaaS, no healthcare or finance data."

Step 2. The agent responds with a confirmation summary of the profile it parsed and asks three clarifying questions: does the company hire in Illinois or New York, does any team use AI to screen candidates or make employment decisions, does any product feature present AI-generated content to customers. Priya answers no, no, and yes (the product has an AI summarization feature).

Step 3. The agent runs applicability analysis and returns a matrix showing: Texas TRAIGA (applies, disclosure for consumer-facing AI), FTC Section 5 (applies, accuracy of AI claims), NIST AI RMF (voluntary baseline, strongly recommended), EEOC guidance (applies to any future hiring AI), EU AI Act (does not apply, no EU customers or employees), Colorado SB 24-205 (does not apply, no Colorado consumers in consequential decisions).

Step 4. Priya types: "Build the minimum viable pack."

Step 5. The agent runs risk tiering on each of the four tools plus the product feature, runs control mapping, and produces the artifacts in 5.5.

End state. Priya receives a Notion page with four linked documents: an AI Acceptable Use Policy, a tool-specific usage standard table, an AI incident response one-pager, and a disclosure copy block for the product's AI summarization feature. Every section carries inline citations. Total time from first message to artifact: under 20 minutes.

Journey 2: Policy refresh

User. Marcus, General Counsel at a 180-person fintech based in New York with customers in 42 states. The company has a 2023 AI policy drafted before the current regulatory surface existed.

Step 1. Marcus uploads the 2023 policy PDF and types: "Refresh this against what applies today. We lend in Colorado and Illinois and we have an ML-based credit adjacent product."

Step 2. The agent parses the document and returns a profile summary, then asks: is the ML-based product used for a consequential decision as defined in Colorado SB 24-205, does the company deploy any hiring AI, does any customer-facing feature use generative output.

Step 3. Marcus confirms the credit-adjacent model informs a consequential decision in Colorado and Illinois.

Step 4. The agent runs gap analysis and produces a report with three sections: regulations the 2023 policy does not address (Colorado SB 24-205 effective 1 February 2026, Illinois HB 3773 effective 1 January 2026, NIST AI 600-1 GenAI Profile, OCC Bulletin 2025-26, EU AI Act if any EU users), sections of the policy that refer to superseded guidance (the policy cites the rescinded Biden EO 14110), and controls that are vague or unassigned.

Step 5. Marcus types: "Produce the redline."

End state. Marcus receives a redlined Word document with tracked changes, a change log summarizing each edit with the controlling regulation, and a separate memo listing the three decisions that require a human policy owner (whether to appoint a model risk officer, whether to commission an algorithmic impact assessment for the credit-adjacent model, whether to extend the policy to cover EU visitors to the marketing site).

Journey 3: Specific regulation question

User. Dana, HR lead at a 40-person manufacturing company in Peoria, Illinois. Just heard about HB 3773 in a SHRM webinar.

Step 1. Dana types: "I run HR for a 40 person Illinois company. Someone said HB 3773 hits us January 1. What do I have to do?"

Step 2. The agent confirms the profile (Illinois employer, under 250 employees, effective 1 January 2026) and asks: does the company currently use any AI tool in recruiting, hiring, promotion, discipline, termination, or compensation decisions, including resume screening, video interview analysis, or productivity scoring.

Step 3. Dana says the company uses a resume screening feature inside its ATS and an AI note-taker in interviews.

Step 4. The agent returns a one-page action brief with four sections: what HB 3773 requires (amendments to 820 ILCS 42, notice to employees, prohibition on AI that produces discriminatory impact on protected classes), what this means for Dana's two tools (the ATS screening is in scope, the note-taker is likely out of scope if it does not score candidates), the steps to be ready by 1 January 2026 (vendor diligence letter template, notice language for candidates, internal policy addendum, bias audit decision), and what to ask the ATS vendor (seven specific questions with citations).

End state. Dana gets a single-page PDF with the action brief, a second page with the candidate notice language and the vendor diligence letter, and an offer from the agent to run the same analysis against any hiring tool the company adds later. Total time from first message to artifact: under 10 minutes.

5.4 Failure Modes and Design Defenses

1. **Hallucinating a regulation that does not exist.** Failure looks like a citation to "California AB 1047" being presented as enacted law. Defense: retrieval is constrained to the Supabase knowledge base; no citation may appear in output unless it links back to a record with a live `source_url` and a `retrieved_at` timestamp within the last 180 days. The generation prompt refuses to produce a citation that the retrieval layer did not surface.

2. **Citing a superseded version.** Failure looks like quoting EO 14110 after its rescission. Defense: every Tier A record has a `superseded_by` field. The retrieval layer filters out superseded records by default, and a superseded citation can only appear when the agent is explicitly asked for historical context, with a label saying so.

3. **Over-applying the EU AI Act to a pure-US company.** Failure looks like a 50-person Texas SaaS getting a 30-page policy full of Article 9 risk management system language. Defense: applicability analysis is the first move in every workflow, and downstream tools receive a filtered regulation set. The prompt template for drafting refuses to import clauses from regulations marked `applies = no`.

4. **Under-applying state law.** Failure looks like missing Colorado SB 24-205 for a company that sells into Colorado. Defense: applicability analysis runs against a state-by-state matrix, not just the state of incorporation. The profile capture step requires customer geography and employee geography as separate fields.

5. **Generic output that does not fit the client.** Failure looks like a policy that reads like a template with the company name swapped in. Defense: control mapping filters the register by headcount band, industry, and tool inventory. Any artifact that does not cite at least three client-specific facts in its first page is rejected by a post-generation quality check.

6. **Losing context on what the client already has.** Failure looks like the agent telling a client to write a policy they already have, or duplicating an existing control. Defense: persistent client memory in Supabase. Every engagement writes the tool inventory, existing documents, and prior recommendations to a `client_context` table that the agent reads at the top of every session.

7. **Recommending vendor products without disclosure.** Failure looks like "use Credo AI" appearing in output without a disclosure flag. Defense: vendor recommendations are gated behind a `commercial_recommendation` tool that requires a disclosure block in the output and is turned off by default for governance artifacts. Tool selection inside artifacts is vendor-neutral by design.

8. **Drifting out of date.** Failure looks like an artifact dated April 2026 citing the February 2024 version of the NIST GenAI Profile. Defense: every artifact header carries a `knowledge_base_version` stamp and the agent refuses to generate if any Tier A record used in the artifact has a `retrieved_at` older than 90 days without a human override.

5.5 MVP Definition

Target customer for v1. US-based, 20 to 250 employees, headquartered outside California and Colorado for the first 10 engagements, operating in a non-regulated industry (B2B SaaS, professional services, light manufacturing, agency, e-commerce). No healthcare PHI, no consumer finance lending decisions, no K-12 or higher ed, no EU operations, no government contracts.

The four artifacts v1 produces.

1. **AI Acceptable Use Policy (2 to 4 pages).** Scope, definitions, approved tools, prohibited uses, data handling rules, human review requirements, incident reporting, policy owner, review cadence. Written in plain language at a reading level a line manager can act on.

2. **Tool Usage Standard (single page matrix).** One row per AI tool the company uses. Columns: tool, approved use cases, prohibited use cases, data classes allowed, enterprise controls enabled, owner.

3. **AI Incident Response One-Pager.** Three pages covering detection triggers, triage decision tree, escalation contacts, customer and regulator notification thresholds, and a short runbook for the four most likely incidents (data leak via prompt, hallucinated customer-facing output, vendor breach, biased or discriminatory output).

4. **Disclosure Copy Block Library.** Pre-written language for customer-facing AI disclosures (product features, chat interactions, AI-generated content), employee notices (for any Illinois or New York staff), and vendor diligence letters.

Out of scope for v1. EU operations and any Article 9 risk management system documentation, regulated industries (healthcare, finance, education, legal, government), board-level materials and

board committee charters, continuous monitoring and ongoing assurance reports, bias audit execution (agent produces the scope of work, not the audit itself), litigation-ready documentation.

Success metric for v1. Three paying engagements completed within 90 days of launch, each delivered inside 10 business days, each generating at least one paid follow-on (retainer, audit scope, policy refresh in 12 months) or one referral. Secondary metric: artifact citation accuracy above 98 percent on spot checks, measured by sampling 20 citations per engagement and verifying each against the live source.

5.6 Knowledge Ops and Update Mechanisms

The knowledge base is only as useful as its freshness. The update pipeline runs on the stack already in place.

Firecrawl watch list. A scheduled scrape runs daily against Tier A and Tier C URLs and weekly against Tier B. Each scrape returns the full content and a content hash. The hash is compared against the last known hash in Supabase. No change, no action. Change detected, the diff is written to a `kb_changes` row and an n8n webhook fires.

n8n review workflow. The webhook payload lands in an n8n workflow that creates a Notion review card in the "KB Review Queue" database with the source, the diff, a preview of the proposed new version, and links to any artifacts that cite the old version. Boubacar reviews, approves or rejects, and the workflow promotes the new version to the active KB and stamps `superseded_by` on the prior record. Rejected changes are logged but not promoted.

Supabase schema sketch.

- `kb_sources`: `id`, `tier`, `name`, `url`, `jurisdiction`, `update_cadence`.
- `kb_records`: `id`, `source_id`, `clause_ref`, `content`, `plain_summary`, `retrieved_at`, `effective_date`, `superseded_by`.
- `kb_changes`: `id`, `source_id`, `detected_at`, `diff`, `status` (pending / approved / rejected), `reviewer`.
- `kb_citations`: `id`, `record_id`, `artifact_id`, `client_id`, `cited_at`.
- `client_context`: `id`, `client_name`, `profile_json`, `tool_inventory`, `existing_docs`, `last_engagement_at`.

Watched source URLs for v1 seed (15 sources).

1. EUR-Lex Regulation (EU) 2024/1689 consolidated text.

2. NIST AI Resource Center AI RMF page.
3. NIST AI 600-1 Generative AI Profile page.
4. ISO/IEC 42001 standard page on iso.org.
5. Colorado General Assembly SB 24-205 bill page.
6. Texas Legislature HB 149 bill page.
7. Illinois General Assembly HB 3773 and 820 ILCS 42 pages.
8. NYC DCWP Local Law 144 guidance page.
9. California Legislative Information portal tracking SB 53 and AB 2013.
10. White House OMB memoranda index.
11. EEOC technical assistance on AI and Title VII.
12. FTC business guidance and press release feed filtered for AI.
13. IAPP Global AI Law and Policy Tracker.
14. Cooley AI practice insights page.
15. Stanford HAI policy publications page.

Additional Tier C watches at launch: OpenAI Usage Policies, Anthropic Usage Policy, Google Generative AI Prohibited Use Policy, Microsoft Responsible AI Standard page, AWS Responsible AI page.

Practitioner Action Box

In the next seven days: set up the Supabase knowledge schema defined in 5.6 and seed it with five Tier A sources: EU AI Act 2024/1689, NIST AI RMF 1.0, NIST AI 600-1, Colorado SB 24-205, and Illinois HB 3773. Write the Firecrawl watch entries for each, wire the n8n change-detection workflow to a Notion review card, and verify the end-to-end loop by making a trivial edit to a test source and confirming the review card arrives. Starting with the schema and the seed, not the agent logic, is the right sequencing because the agent is only as good as the retrieval layer underneath it. Building the crew first against an empty or unversioned knowledge base produces a confident hallucinator; building the knowledge spine first gives the crew a constrained, citable surface on day one. The first five seeded sources also cover roughly 80 percent of the applicability questions a US SMB will ask in v1, which means the agent becomes demonstrably useful the moment the crew layer goes on top.

PART 6: MASTERY TIERING ACROSS THE PRACTICE

Three tiers. Each one raises the price you can charge, the rooms you get invited into, and the depth of problem a client will hand you. A Tier 1 practitioner sells a document. A Tier 2 practitioner sells a retainer. A Tier 3 practitioner sells a point of view that the market pays to access. The gap between them is not talent. It is accumulated reps against named artifacts, named frameworks, and named failure cases.

6.1 Tier 1: The Floor (Required for Any Paid Engagement)

Tier 1 is the minimum competence threshold for taking money from a small or midmarket business to write AI governance. Below this line you are guessing. At this line you can write a defensible first draft and survive a client asking you why.

What you know

The four deliverable types. Framework (the operating model: roles, decision rights, escalation paths, review cadence). Policy (the binding rules: acceptable use, data handling, vendor intake, incident response). Playbook (the runbook: step by step procedures for specific situations like vendor onboarding, model change, incident triage). Audit (the evidence file: the log, the artifact trail, the control test results that prove the policy is actually running).

The 16-section anatomy of a governance document. Purpose and scope, definitions, governance roles and decision rights, risk classification scheme, acceptable use, prohibited use, data handling and minimization, vendor and third party management, model lifecycle controls (pre-deployment, deployment, post-deployment), human oversight and human in the loop requirements, transparency and disclosure obligations, incident response and reporting, record keeping and documentation, training and awareness, review cadence and version control, and enforcement and exceptions.

EU AI Act core tiers. Prohibited systems under Article 5 (social scoring, real-time biometric categorization in public spaces subject to narrow exceptions, emotion recognition in workplace and education, predictive policing based solely on profiling, untargeted facial image scraping). High-risk under Annex III (biometrics, critical infrastructure, education access, employment decisions, essential services, law enforcement, migration, administration of justice). GPAI obligations under

Articles 51 through 55 with the systemic risk threshold at 10^25 FLOPs. Limited risk with transparency duties under Article 50 (chatbots must disclose, synthetic content must be labeled). Minimal risk with voluntary codes. Extraterritoriality under Article 2: the Act applies when output is used in the EU, regardless of where the provider sits.

NIST AI RMF 1.0. Four functions: Govern (culture, accountability, policy), Map (context, categorization, impact assessment), Measure (metrics, testing, evaluation), Manage (response, monitoring, recovery). The GenAI Profile published as NIST AI 600-1 adds twelve specific risk categories for generative systems including confabulation, dangerous or violent recommendations, data privacy, environmental, human AI configuration, information integrity, information security, intellectual property, obscene and abusive content, toxicity bias and homogenization, value chain and component integration, and CBRN information. Know which RMF subcategories map to each.

ISO/IEC 42001 at the conceptual level. The first certifiable AI management system standard. Structured like ISO 27001 with Plan Do Check Act. Clause structure covers context, leadership, planning, support, operation, performance evaluation, improvement. Annex A controls are the operational teeth. Certifiable by accredited third parties. This is the artifact a Fortune 500 buyer asks for when an SMB sells into their supply chain.

Active US state laws. Colorado SB 24-205 (Colorado AI Act, effective February 1 2026, high-risk AI systems, duty of reasonable care on developers and deployers, algorithmic discrimination focus, consumer notice and appeal rights). Texas TRAIGA via HB 149 (Texas Responsible AI Governance Act, effective January 1 2026, state agency constraints, disclosure obligations, AG enforcement). Illinois HB 3773 (amends the Illinois Human Rights Act effective January 1 2026, employer use of AI in employment decisions, notice requirement, disparate impact liability). NYC Local Law 144 (automated employment decision tools, bias audit required within one year prior to use, candidate notice, effective since July 2023). Utah SB 149 (AI Policy Act, effective May 1 2024, consumer protection disclosure, regulated occupation disclosure, safe harbor through the Office of AI Policy). California SB 53 (Transparency in Frontier AI Act, large frontier developer reporting, critical incident reporting to the Office of Emergency Services) and AB 2013 (generative AI training data transparency, effective January 1 2026, public posting of training data documentation).

Federal surface. Executive Order 14179 replaced EO 14110 in January 2025, removing the Biden-era safety testing and reporting requirements and reorienting federal posture toward AI dominance. OMB Memo M-25-21 governs federal agency use of AI. OMB Memo M-25-22 governs federal agency procurement of AI. Both replace the earlier M-24-10 and M-24-18. They still require agency Chief AI Officers, use case inventories, and minimum risk management practices for high impact AI, so the federal floor survived the EO change even if the ceiling shifted.

Sector overlays at the conceptual level. EEOC guidance on AI in employment decisions and the disparate impact framework under Title VII. FTC enforcement posture demonstrated in the Rite Aid facial recognition consent order (December 2023, five year ban, deletion obligations, algorithmic disgorgement exposure). ONC HTI-1 rule with the FAVES principles (Fair, Appropriate, Valid, Effective, Safe) governing decision support interventions in certified EHRs. Federal Reserve SR 11-7 on model risk management and the newer OCC Bulletin 2025-26 extending similar expectations with AI-specific considerations for national banks.

Named failure cases. Samsung Semiconductor 2023 (engineers pasted proprietary source code into ChatGPT, triggered company-wide generative AI ban, canonical shadow AI case). Moffatt v. Air Canada 2024 (British Columbia Civil Resolution Tribunal held Air Canada liable for chatbot misinformation about bereavement fares, demolished the "separate entity" defense). EEOC v. iTutorGroup 2023 (first EEOC AI discrimination settlement, 365,000 dollars, algorithm auto-rejected older applicants). McDonald's Paradox.ai 2025 (McHire AI recruiter exposed 64 million applicant records through a default password, demonstrating vendor failure is your failure). Deloitte Australia 2025 (440,000 AUD government report contained fabricated citations and a nonexistent academic quote, forced partial refund and public correction).

Eight foundational practitioner principles. One: governance is a running system, not a document. Two: the artifact must be auditable, meaning every control has evidence attached. Three: vendor risk is your risk. Four: human oversight is meaningful only if the human can actually override. Five: data minimization beats data protection every time. Six: disclosure is the cheapest control you own. Seven: incident response plans are tested or they are fiction. Eight: the framework names never appear in client-facing language.

What you can deliver

A framework document, a policy pack, an intake playbook, and an audit checklist for an SMB with fewer than 500 employees and fewer than 10 AI touchpoints. Delivery window: two to four weeks. Price range: 8,000 to 25,000 dollars for the package.

What you can defend

Three questions a client will ask, and the answers you give without hedging. First, "Does the EU AI Act apply to us?" Answer: if any of your output is used by a person or system in the EU, Article 2 pulls you in, regardless of where you are incorporated. We assess exposure based on output destination and deployment context. Second, "Do we need ISO 42001?" Answer: not yet unless you are selling into a buyer that requires it. We build toward 42001 compatibility so certification is a 90

day exercise when you need it, not a 12 month rebuild. Third, "What happens if our vendor's model hallucinates and a customer is harmed?" Answer: Moffatt v. Air Canada settles that. You are liable. We control this through vendor contract terms, human oversight gates, disclosure, and incident response.

Tier 1 resources

IAPP AIGP Body of Knowledge v2.1 as the single best structured overview of the field. NIST AI RMF 1.0 and the GenAI Profile AI 600-1 directly from nist.gov. EU AI Act official text on EUR-Lex (Regulation 2024/1689) and the EU AI Office guidance pages. Cooley AI practice page for client-ready plain-English summaries. Latham and Watkins AI tracker for regulatory developments. Perkins Coie and K and L Gates alert series for implementation-level client memos. Algorithmic Justice League research archive for evidence base on bias and harms, particularly Buolamwini and Gebru Gender Shades work.

Tier 1 exit test

You can sit in a room with an SMB owner and a general counsel and answer, in under 60 seconds each, the three questions above. You can produce a framework + policy + playbook + audit package in three weeks. You can name all 16 anatomy sections without a cheat sheet. You can recite the EU AI Act tier structure and the five active US state laws by effective date.

30/60/90 day action list to Tier 1

Days 1 through 30: read the AIGP Body of Knowledge v2.1 cover to cover. Read the EU AI Act articles 1 through 15, 50 through 55, and Annex III. Read NIST AI RMF 1.0 and the GenAI Profile. Build a first-pass 16-section governance template in your own voice. Days 31 through 60: write a mock framework + policy + playbook + audit for a fictional 200-person healthcare staffing firm. Have a lawyer friend red-pen the policy. Days 61 through 90: register for IAPP AIGP. Schedule the exam. Publish one article on a named failure case using your own analysis of the public record.

6.2 Tier 2: Progressive Mastery (Retainer-Grade)

Tier 2 is the line where a client stops paying you for a document and starts paying you a monthly retainer to be on call when something breaks. You reach Tier 2 when you can operate on the artifact after it is written, not just produce it.

What you know

Vendor review. Reading an AI addendum is its own skill. Ten red flags to spot on first pass: unlimited training rights on customer data, broad sublicense language, no deletion obligation on termination, no indemnification for IP infringement from model output, no incident notification SLA, no audit rights, no model change notification, unilateral right to modify the addendum, arbitration in a hostile forum, and a liability cap below the realistic harm value. The three most important clauses to negotiate: training rights on customer data (must be opt-out or prohibited), IP indemnification for output (must cover both input and output, not just input), and notification of material model change (must give the customer a right to test and a right to exit).

Model cards and system cards. What they contain: model architecture, training data summary, intended use, known limitations, evaluation results on named benchmarks, bias evaluations across protected attributes, and deprecation policy. What they leave out almost universally: training data provenance in detail, copyrighted material exposure, hazard evaluations against CBRN risks in non-frontier systems, downstream harm data, and red-team findings that would damage marketing. Pressure-test a vendor claim by asking for the evaluation dataset composition, the holdout methodology, the disaggregated results across the protected classes relevant to the deployment, and the red-team report (not the summary).

Red team basics. For a small deployment: define the attack surface (prompt injection, jailbreak, data exfiltration, training data extraction, output manipulation), script 25 to 50 structured probes across those categories, run them through the system with realistic user context, record every input, output, and judgment (pass, fail, concern), categorize findings by severity (critical, high, medium, low), produce a written report that a non-technical executive can read. The artifact is the report, not the probes.

Tabletop exercises. A 90-minute tabletop for an SMB: ten minutes of setup and ground rules, three scenarios of 20 minutes each (one data leak through vendor, one output harm to customer, one regulatory inquiry), 10 minutes of debrief per scenario, 10 minutes of action item capture at the end. Scenarios pulled from the named failure cases and adapted to the client's context. Deliverable is an action register with owner, deadline, and success criterion.

Sector overlays in depth. HIPAA plus AI: PHI in prompts is a breach, business associate agreements must cover AI subprocessors, de-identification under Safe Harbor method or Expert Determination method, HTI-1 FAVES for decision support. FCRA plus AI: adverse action notice requirement when an algorithm contributes to denial, accuracy and dispute procedures, permissible purpose for data use. GLBA plus AI: Safeguards Rule applies to AI systems touching nonpublic personal information, risk assessment obligation, vendor oversight. Employment law plus AI: Title VII disparate impact, ADEA for age, ADA for disability and medical inquiry, state laws layered on top.

Cross-framework matrix thinking. Take one control, for example "human oversight of high impact decisions," and map it: NIST AI RMF MANAGE 2.3, ISO 42001 A.9 operational controls, EU AI Act Article 14, Colorado AI Act duty of reasonable care, NIST GenAI Profile MS-2.9. One artifact, one control, five legal anchors. Do that for 40 controls and you have a matrix product.

Writing the auditable artifact. The policy says "human oversight is required for high impact decisions." The auditable artifact is the decision log that shows the human actually reviewed, the timestamp, the override rate, the sampled spot-check. Without that log the policy is a press release.

What you can deliver

Vendor review memos, red team reports, tabletop facilitation, sector-specific overlay policies, ongoing advisory retainer with quarterly audit, and a cross-framework control matrix customized to the client. Price range: 4,000 to 12,000 per month on retainer, plus project work.

What you can defend

A general counsel asks you "how do I know our AI policy is actually running?" You answer with the audit artifact file, the sample log, the override rate trend, and the last incident review. A buyer asks "walk me through your vendor intake process end to end." You walk them from intake form, to legal review, to security review, to pilot gates, to production gates, to ongoing monitoring, to offboarding.

Tier 2 resources

Reid Blackman "Ethical Machines" for the operating model view. Cathy O'Neil "Weapons of Math Destruction" for the harm cases and the structural critique. Virginia Eubanks "Automating Inequality" for the public sector pattern. Named people to follow: Rumman Chowdhury (Humane Intelligence, red team methodology), Margaret Mitchell (Hugging Face, model cards), Timnit Gebru (DAIR, dataset and foundation model critique), Gary Marcus for the skeptical AGI read and risk framing. Communities: IAPP AI Governance Center, ForHumanity (independent audit certification, the FHCA credential), Responsible AI Institute (RAII assessment tools). Courses: MIT Sloan AI Strategy executive program, Stanford HAI resources and the HAI policy briefs, IAPP AIGP certification track, and the Berkeley CLTC AI risk resources.

30/60/90 day action list to Tier 2

Days 1 through 30: run a real vendor review on three live AI SaaS contracts you can get access to (your own, a friend's company, or a pro bono client). Write the memo for each. Days 31 through 60:

design and facilitate one tabletop exercise for a willing small business. Capture the action register. Days 61 through 90: build the cross-framework matrix covering at least 30 controls across NIST, ISO 42001, EU AI Act, and two US state laws. Publish the matrix as a free download behind an email capture.

6.3 Tier 3: Depth (Where Boubacar Goes)

Tier 3 is field-leading. At Tier 3 you are not competing on price, you are competing on point of view. Clients hire you because they read something you wrote, heard you at a conference, or saw you cited. The deliverable is you.

What you know

A proprietary diagnostic. Eight lenses applied rigorously, each weighted equally, never named to clients. Theory of Constraints to find the binding bottleneck in the AI governance function. Jobs to Be Done to understand what the organization is actually hiring AI to do. Lean and waste elimination to strip policy overhead that adds no control. Behavioral economics to predict where employees will route around the policy and design for that. Systems thinking to trace second and third order effects of a governance decision across the org. Design thinking to build the artifact so the user will actually use it. Organizational development to handle the culture and change management dimension. AI strategy to connect governance to the actual value model. In client language this shows up as "we look at the problem from multiple angles before prescribing a fix." The frameworks stay in your head.

Case studies you built yourself. At least three, at varying size. Published where you can, private where client confidentiality requires. Each case study names the situation, the diagnosis, the intervention, the result, and the lessons. A case study body of work is what a procurement officer reads before handing you a contract.

A governance agent or toolset you built and maintain. Your own tool, with your name on it, that a practitioner would actually use. A vendor intake bot. A cross-framework matrix generator. A tabletop scenario library. A policy linter that flags missing sections in a draft. The tool is proof of depth and a lead generation channel in itself.

Relationships with 2 to 3 specialist law firms for co-representation. One big law firm for Fortune 500 work you refer up. One boutique privacy and AI firm for mid-market partnership. One employment-specialist firm for the EEOC and state employment AI cases. You trade referrals, co-author pieces, and co-present at conferences.

A seat at a standards body or working group. NIST Generative AI Working Group. ISO/IEC JTC 1/SC 42 artificial intelligence subcommittee (through the US TAG administered by ANSI/INCITS). IEEE P7000 series working groups. ForHumanity Fellows. The seat gives you early signal on where the field is moving and a platform to shape it.

Cross-framework matrix as a product you license or give away. A Tier 2 practitioner builds the matrix for one client. A Tier 3 practitioner licenses the matrix to 20 practitioners and 5 law firms, or gives it away to build authority and drive inbound.

Original thinking published in long form. A body of work that gets cited. Articles in Lawfare, IAPP Privacy Advisor, Stanford HAI blog, Harvard Business Review. A book manuscript in progress. A newsletter with 2,000 paid subscribers in the target ICP. The Google Scholar citation count on your name is nonzero.

What you can deliver

Board advisory retainers, keynote talks, expert witness work, co-authored whitepapers with law firm partners, a published book or body of articles, and a tool or platform that practitioners in the field actually use. Price range: 400 to 1,200 per hour, 25,000 to 75,000 for board-level engagements, keynote fees, book advance and speaking circuit.

What you can defend

A board asks "what is your point of view on the EU AI Act enforcement trajectory over the next 18 months?" You answer with a specific thesis, grounded in the Article 50 transparency timeline, the Article 6 delegated act schedule, and the EU AI Office staffing pattern. A journalist asks for a quote on the Deloitte Australia case and you give them three paragraphs of original analysis that ends up in the piece.

Tier 3 resources

Conferences to speak at: IAPP Global Privacy Summit (Washington DC, the premier privacy and AI governance stage), RSA Conference (security angle on AI), NeurIPS Responsible AI track (the academic frontier), WAICF World AI Cannes Festival (European enterprise angle), FAccT (ACM Conference on Fairness Accountability and Transparency, the academic responsible AI conference). Working groups: NIST GAI WG, ISO/IEC JTC 1/SC 42, IEEE P7003 Algorithmic Bias Considerations and the broader P7000 series, Partnership on AI working groups, ForHumanity independent audit committees. Outlets for publication: Lawfare (policy and national security), IAPP Privacy Advisor (practitioner audience), Harvard Business Review (executive audience), Stanford HAI blog (policy

and research bridge), MIT Sloan Management Review (executive operations angle), and Brookings TechStream (policy bridge).

30/60/90 day action list to Tier 3

Days 1 through 30: pitch one long-form article to Lawfare or IAPP Privacy Advisor. Apply to one standards working group seat (NIST GAI WG and ForHumanity Fellows are the most accessible entry points). Publish one case study from your own practice with client consent or a disguised version. Days 31 through 60: open a co-representation conversation with one boutique privacy and AI law firm. Schedule a co-authored piece. Ship the first public version of your governance agent or toolset. Days 61 through 90: submit a conference talk proposal to IAPP Global Privacy Summit or FAccT. Draft the outline of a book or a 10-part essay series. Publish the cross-framework matrix as a free download with email capture and a paid consulting upsell.

Practitioner Action Box

In the next seven days: ship a one-page US state AI law cheat sheet covering the six active state laws (Colorado SB 24-205, Texas HB 149, Illinois HB 3773, NYC Local Law 144, Utah SB 149, California SB 53, California AB 2013) with effective date, covered entities, key duties, penalties, and a one-line gotcha for each. Design it cleanly, brand it as a Catalyst Works artifact, publish it as a free PDF behind an email capture on the site, post it as a LinkedIn carousel and an X thread, and send it as a signature line asset in every outbound email for the next 30 days. This artifact compounds because it is the single most-searched practical question an SMB has right now ("does this apply to me?"), it is cheap to update quarterly, it earns inbound from procurement and HR leaders who find it before they find you, and it signals the one thing a Tier 3 practitioner must signal: that you are tracking the field at the statute level, not the headline level. It is the shortest path from a Tier 1 document to a Tier 3 reputation asset.